

DevelopersHub Corporation

Vulnerability Report

Week 5 - Security Testing & Vulnerability Analysis

Application: automationexercise.com

Tool: OWASP ZAP 2.17.0

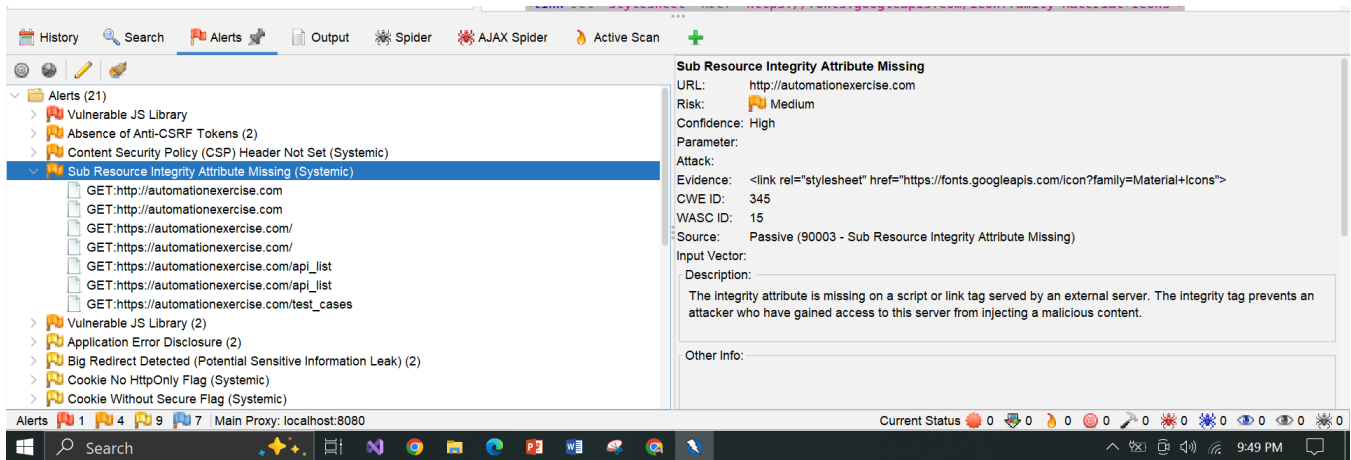
Date: May 25, 2026

Prepared by: Kashan Karim SQA Intern - DevelopersHub Corporation

1. Scope and Test Environment

Parameter	Details
Tool Used	OWASP ZAP 2.17.0 (Automated Scan)
Target URL	https://automationexercise.com
Scan Type	Automated Scan (Traditional Spider + Active Scan)
Total Alerts Found	20 vulnerabilities across 4 severity levels
Test Date	May 25, 2026
OS	Windows 10

2. Screenshots



3. Vulnerabilities

Severity	Count	OWASP Categories	Risk Impact
High	1	A06 - Outdated Components	Critical - direct exploitation possible
Medium	5	A01, A03, A05, A08	Significant - may lead to data exposure
Low	8	A02, A05, A07, A08	Moderate - degrades security posture
Informational	6	A05, A07	Low - awareness items for improvement
TOTAL	20	-	-

4. Detailed Vulnerability Report

VUL-001	Vulnerable JS Library	High
OWASP:	A06 - Vulnerable & Outdated Components	
URL:	https://automationexercise.com/static/js/bootstrap.min.js, jquery.js	
Description:	The application loads outdated JavaScript libraries (Bootstrap and jQuery) that contain known security vulnerabilities. Attackers can exploit these to perform XSS or other client-side attacks.	
Steps to Reproduce:	1. Open ZAP - Run Automated Scan 2. Check Alerts - Vulnerable JS Library 3. ZAP identified bootstrap.min.js and jquery.js as vulnerable versions	
Suggested Fix:	Upgrade Bootstrap and jQuery to their latest stable versions. Monitor libraries using tools like Snyk or Dependabot.	
VUL-002	Absence of Anti-CSRF Tokens	Medium
OWASP:	A01 - Broken Access Control	

URL:	https://automationexercise.com/login, /signup
Description:	Several forms lack proper CSRF token validation, making it possible for an attacker to trick authenticated users into submitting malicious requests.
Steps to Reproduce:	1. Open ZAP - Run Automated Scan 2. Check Alerts - Absence of Anti-CSRF Tokens 3. ZAP found CSRF token missing on login and signup POST endpoints
Suggested Fix:	Implement CSRF tokens on all state-changing forms. Validate the token server-side on every POST request.

VUL-003	Content Security Policy (CSP) Header Not Set	Medium
OWASP:	A05 - Security Misconfiguration	
URL:	https://automationexercise.com/ (all pages)	
Description:	The application does not send a Content-Security-Policy HTTP header. Without CSP, the browser has no restrictions on which resources it can load, increasing XSS attack surface.	
Steps to Reproduce:	1. Open ZAP - Run Automated Scan 2. Check Alerts - CSP Header Not Set 3. Inspect response headers - Content-Security-Policy header is absent	
Suggested Fix:	Add a strict Content-Security-Policy header to all HTTP responses, e.g., default-src 'self'; script-src 'self'.	

VUL-004	Sub Resource Integrity Attribute Missing	Medium
OWASP:	A08 - Software & Data Integrity Failures	
URL:	https://automationexercise.com/ (external JS/CSS files)	
Description:	External scripts and stylesheets are loaded without the 'integrity' attribute. If a CDN is compromised, malicious code could be injected and executed in users' browsers.	
Steps to Reproduce:	1. Run ZAP Automated Scan 2. Check Alerts - Sub Resource Integrity Attribute Missing 3. View page source - external [script] tags lack integrity= attribute	
Suggested Fix:	Add integrity and crossorigin attributes to all externally loaded scripts and stylesheets using SRI hashes.	

VUL-005	Application Error Disclosure	Medium
OWASP:	A05 - Security Misconfiguration	
URL:	POST https://automationexercise.com/login, /signup	
Description:	The application reveals internal error details in HTTP responses. This can expose stack traces, framework versions, and file paths to attackers.	
Steps to Reproduce:	1. Run ZAP Automated Scan 2. Check Alerts - Application Error Disclosure 3. ZAP detected error details returned in POST /login and /signup responses	
Suggested Fix:	Disable detailed error messages in production. Return generic error messages to users and log detailed errors server-side only.	

VUL-006	Big Redirect Detected (Potential Sensitive Information Leak)	Medium
OWASP:	A03 - Injection / Information Disclosure	
URL:	GET http://automationexercise.com, http://automationexercise.com/	
Description:	The application returns unusually large redirect responses that may contain sensitive information in the redirect body.	
Steps to Reproduce:	1. Run ZAP Automated Scan 2. Check Alerts - Big Redirect Detected 3. HTTP redirect from http:// to https:// contains large response body	
Suggested Fix:	Ensure redirect responses contain no body content. Implement 301 redirects that send empty bodies.	

VUL-007	Cookie No HttpOnly Flag	Low
OWASP:	A02 - Cryptographic Failures	
URL:	GET https://automationexercise.com/ (multiple pages)	
Description:	Session cookies are set without the HttpOnly flag, meaning JavaScript code can read cookie values. This enables session theft via XSS attacks.	
Steps to Reproduce:	1. Run ZAP Automated Scan 2. Check Alerts - Cookie No HttpOnly Flag 3. Inspect Set-Cookie response header - HttpOnly attribute is missing	

Suggested Fix:	Set the HttpOnly flag on all session cookies: Set-Cookie: sessionId=...; HttpOnly; Secure
-----------------------	--

VUL-008	Cookie Without Secure Flag	Low
OWASP:	A02 - Cryptographic Failures	
URL:	GET https://automationexercise.com/ (multiple pages)	
Description:	Cookies are set without the Secure flag, meaning they could be transmitted over unencrypted HTTP connections and intercepted by attackers.	
Steps to Reproduce:	1. Run ZAP Automated Scan 2. Check Alerts - Cookie Without Secure Flag 3. Inspect Set-Cookie header - Secure attribute is absent	
Suggested Fix:	Add the Secure flag to all cookies: Set-Cookie: sessionId=...; Secure; HttpOnly	

VUL-009	Cross-Domain JavaScript Source File Inclusion	Low
OWASP:	A08 - Software & Data Integrity Failures	
URL:	GET https://automationexercise.com/ (multiple pages)	
Description:	JavaScript files are loaded from external domains. If those domains are compromised, malicious scripts could be injected into the application.	
Steps to Reproduce:	1. Run ZAP Automated Scan 2. Check Alerts - Cross-Domain JS Source File Inclusion 3. View page source - <script src=> tags point to external domains	
Suggested Fix:	Host all JavaScript files locally or use SRI (Subresource Integrity) to verify external script integrity.	

VUL-010	In Page Banner Information Leak	Low
OWASP:	A05 - Security Misconfiguration	
URL:	POST https://automationexercise.com/login, /signup	
Description:	The application leaks server or framework version information via in-page banners or HTML comments, giving attackers useful reconnaissance data.	
Steps to Reproduce:	1. Run ZAP Automated Scan 2. Check Alerts - In Page Banner Information Leak 3. View page source - version strings visible in HTML	
Suggested Fix:	Remove all version information from HTML responses, error pages, and HTTP headers.	

VUL-011	Server Leaks Info via X-Powered-By Header	Low
OWASP:	A05 - Security Misconfiguration	
URL:	GET https://automationexercise.com/ (all pages)	
Description:	The server sends an X-Powered-By HTTP header revealing the backend technology stack (e.g., Django, Express). Attackers use this for targeted exploitation.	
Steps to Reproduce:	1. Run ZAP Automated Scan 2. Check Alerts - Server Leaks Info via X-Powered-By 3. Inspect response headers - X-Powered-By header is present	

Suggested Fix:	Remove or suppress the X-Powered-By header in server configuration.
-----------------------	--

VUL-012	Strict-Transport-Security Header Not Set	Low
OWASP:	A05 - Security Misconfiguration	
URL:	GET https://automationexercise.com/ (multiple pages)	
Description:	The HTTP Strict-Transport-Security (HSTS) header is not set. Without HSTS, browsers may allow HTTP connections, making the site vulnerable to downgrade attacks.	
Steps to Reproduce:	1. Run ZAP Automated Scan 2. Check Alerts - Strict-Transport-Security Header Not Set 3. Inspect response headers - HSTS header is absent	
Suggested Fix:	Add header: Strict-Transport-Security: max-age=31536000; includeSubDomains; preload	

VUL-013	X-Content-Type-Options Header Missing	Low
OWASP:	A05 - Security Misconfiguration	
URL:	GET https://automationexercise.com/cdn-cgi/styles/cf.errors.css	
Description:	The X-Content-Type-Options header is not set, allowing browsers to MIME-sniff responses. This can lead to content injection attacks.	
Steps to Reproduce:	1. Run ZAP Automated Scan 2. Check Alerts - X-Content-Type-Options Header Missing 3. Inspect response headers on CSS files - header is absent	
Suggested Fix:	Add header: X-Content-Type-Options: nosniff to all HTTP responses.	

VUL-014	User Controllable HTML Element Attribute (Potential XSS)	Low
OWASP:	A03 - Injection (XSS)	
URL:	POST https://automationexercise.com/contact_us, /signup	
Description:	User-supplied input is reflected in HTML element attributes without proper sanitization, creating a potential Cross-Site Scripting (XSS) vector.	
Steps to Reproduce:	1. Run ZAP Automated Scan 2. Check Alerts - User Controllable HTML Element Attribute 3. Found on contact_us and signup POST endpoints with user input reflected	
Suggested Fix:	Sanitize and encode all user input before reflecting it in HTML. Use context-aware output encoding.	

VUL-015	Information Disclosure - Suspicious Comments	Informational
OWASP:	A05 - Security Misconfiguration	
URL:	GET https://automationexercise.com/static/js/main.js	
Description:	The JavaScript source code contains comments that may reveal internal logic, developer notes, or sensitive configuration details.	
Steps to Reproduce:	1. Run ZAP Automated Scan 2. Check Alerts - Information Disclosure - Suspicious Comments 3. Open main.js in browser - HTML/JS comments with internal info found	

Suggested Fix:	Remove all debug comments and sensitive notes from production JavaScript files. Use minification to strip comments.
-----------------------	--

VUL-016	Session Management Response Identified	Informational
OWASP:	A07 - Identification & Authentication Failures	
URL:	GET https://automationexercise.com/ (187 instances)	
Description:	ZAP identified session management tokens in 187 HTTP responses across the application. This is informational but indicates the session management surface area is large.	
Steps to Reproduce:	1. Run ZAP Automated Scan 2. Check Alerts - Session Management Response Identified 3. ZAP detected session tokens across 187 URLs	
Suggested Fix:	Ensure all session tokens are securely generated, have appropriate expiry, and are invalidated on logout.	

VUL-017	Authentication Request Identified	Informational
OWASP:	A07 - Identification & Authentication Failures	
URL:	POST https://automationexercise.com/login	
Description:	ZAP identified the login endpoint accepting email and password credentials. This is informational but confirms the authentication endpoint location.	
Steps to Reproduce:	1. Run ZAP Automated Scan 2. Check Alerts - Authentication Request Identified 3. Login POST with csrfmiddlewaretoken, email, password parameters identified	
Suggested Fix:	Ensure the login endpoint is protected by rate limiting, account lockout after failed attempts, and CAPTCHA.	

VUL-018	Re-examine Cache-Control Directives	Informational
OWASP:	A05 - Security Misconfiguration	
URL:	GET https://automationexercise.com/ (multiple pages)	
Description:	Cache-Control headers may be misconfigured, potentially allowing sensitive pages to be cached by browsers or proxies.	
Steps to Reproduce:	1. Run ZAP Automated Scan 2. Check Alerts - Re-examine Cache-Control Directives 3. Inspect Cache-Control headers on authenticated pages	
Suggested Fix:	Set Cache-Control: no-store, no-cache on all authenticated or sensitive pages.	

VUL-019	Retrieved from Cache	Informational
OWASP:	A05 - Security Misconfiguration	
URL:	GET https://automationexercise.com/static/css/ (multiple CSS files)	
Description:	Static resources are being served from cache. While generally acceptable for static assets, it should be verified that sensitive responses are not cached.	

Steps to Reproduce:	1. Run ZAP Automated Scan 2. Check Alerts - Retrieved from Cache 3. CSS files returned with cache headers indicating browser caching
Suggested Fix:	Verify that only public static assets use caching. Sensitive responses must use Cache-Control: no-store.

VUL-020	Modern Web Application	Informational
OWASP:	A05 - Security Misconfiguration	
URL:	GET https://automationexercise.com/ (multiple pages)	
Description:	ZAP identified that the application uses modern web technologies (AJAX, SPAs). This is informational and indicates traditional spidering may have limited coverage.	
Steps to Reproduce:	1. Run ZAP Automated Scan 2. Check Alerts - Modern Web Application 3. Application uses dynamic content loading that may not be fully crawled	
Suggested Fix:	Use ZAP's AJAX Spider with a real browser for more comprehensive scanning of modern web applications.	